



FORMAOS

COMPLIANCE, SIMPLIFIED

CTO HANDOVER PACK · 03

Workflow Mapping

The core execution flows of the platform — how a request travels, how a new tenant is born, how compliance posture is computed, how money is collected, and how code reaches production.

PREPARED
FOR
Farhad
Hussain
Incoming CTO

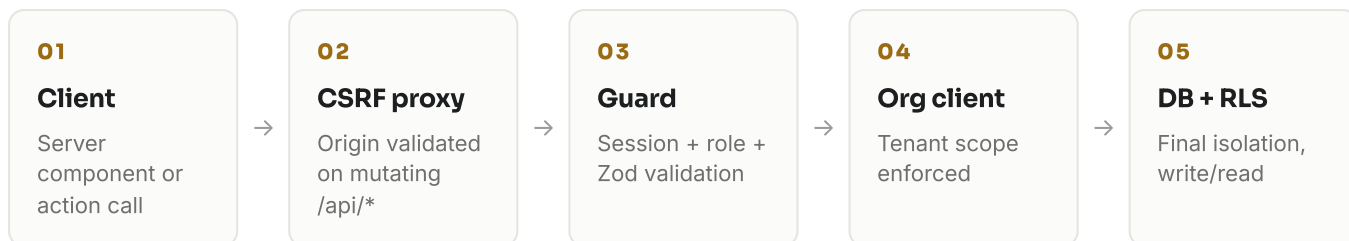
PREPARED
BY
Ejaz
Hussain
Founder

DATE
13 June
2026

CLASSIFICATION
Confidential

How a request travels

Every authenticated action passes through the same layered path. Two independent isolation layers (the org-scoped client and Postgres RLS) mean a single forgotten filter cannot leak another tenant's data.



☐ Application layer ☐ Security checkpoint ☐ Data layer

Why two layers

Server work sometimes uses the service-role key, which bypasses RLS. The org-scoped client guarantees the tenant filter in application code; RLS guarantees it at the database for session-key paths. Belt and braces — deliberately redundant because tenant isolation is the highest-severity property in a compliance product.

New tenant & first login

This is the birth of a customer — and where the current launch blocker lives (step 3).

○ Sign-up

app/(marketing) → /signin → Supabase Auth

User registers or accepts an invite; a Supabase auth user is created.

○ Session bootstrap

POST /api/auth/bootstrap

First authenticated call establishes the tracked session and kicks off workspace provisioning.

○ Tenant provisioning

lib/provisioning · recoverUserWorkspace

Creates the organisation, membership, subscription/trial, resolves industry framework packs and seeds onboarding status — ~30 sequential DB statements. THIS STEP CURRENTLY TIMES OUT (504) FOR NEW USERS UNDER LOAD.

○ Guided first session

/app · StartHereCard

Five guided actions (care plan → goal → progress note → evidence → review task); the dashboard stays focused to just the guide + live tiles until done.

○ Steady state

/app dashboard (command center)

Once the five steps complete (or an incident is logged), the full dashboard returns.

FIX DIRECTION

Collapse the provisioning chain into a single database-side transaction / RPC (round-trips are the multiplier), and/or move provisioning to an async 'setting up your workspace' step. Detailed in Document 04.

The compliance lifecycle

The core value loop: frameworks become controls, controls demand evidence, evidence and evaluations roll up into a live posture score and an audit trail.

○ Framework pack loaded

`framework-packs/*.json`

On tenant setup, industry-relevant packs (e.g. SOC 2, ISO 27001, NDIS) populate the control library.

○ Controls assigned

`lib/compliance, app/app/controls`

Controls get owners, cadence and status; obligations become tasks the team works.

○ Evidence captured

`app/app/vault, lib/evidence`

Documents, credentials and attestations are uploaded and mapped to controls.

○ Posture computed

`lib/compliance-graph.ts`

Controls + evidence + evaluations compute a readiness score and a node-wire compliance graph.

○ Surfaced & exported

`executive dashboard · audit packs`

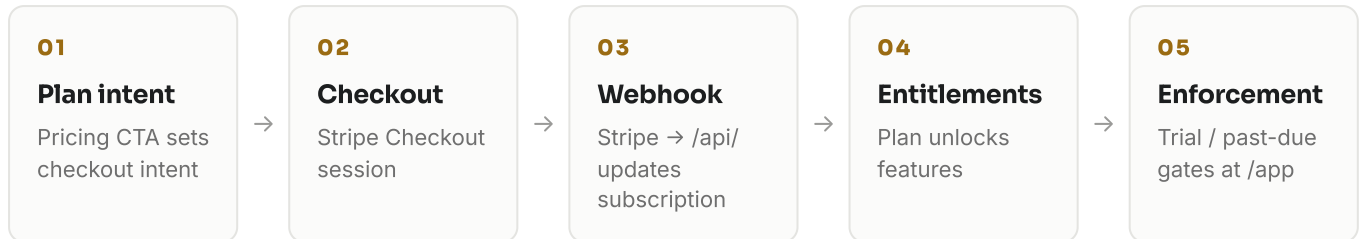
Posture shows on the executive view; audit-ready packs export for assessors.

○ Audit trail anchored

`trigger/ audit-chain-anchor`

Activity is written to a tamper-evident, periodically-anchored log.

Subscription & trial flow



Subscription state is webhook-driven and stored per organisation. The dashboard entry point (`app/app/page.tsx`) enforces it: a `pending_checkout` , `past_due` , `canceled` or `incomplete` status redirects the user to billing rather than the app. Plans map to entitlements that gate features across the product.

STATE	MEANING	USER EXPERIENCE
trialing	In free trial window	Full access; trial nudges shown
active	Paid & current	Full access
past_due	Payment failed	Redirected to billing
pending_checkout	Selected a plan, not paid	Routed into Stripe Checkout

Admin & support workflow

The admin console is the operator surface for running the platform without touching the database directly.

- **Customer-360** — a single org view with members, entitlements, support, activity, sessions, security and exports.
- **Reason-gated mutations** — admin changes require a stated reason and are written to the audit log.
- **Approval-gated high-risk changes** — delegated admins need approval for sensitive actions; founder access is unrestricted.
- **Live ops surfaces** — security, sessions and activity are observable in real time.
- **Immutable audit reads** — unified, legacy-inclusive audit history.

NOTE

The QA / audit runner and platform controls live here too — useful for you and the team to exercise flows safely against real tenants.

Release & deploy workflow

○ Branch

`git checkout -b ...`

Work happens on a feature branch off main.

○ Pull request

GitHub PR

Opening a PR triggers 12 CI workflows + a Vercel preview deployment.

○ CI gates

`build · unit · E2E · a11y · perf · security`

Merge on green real gates. Note the three pre-existing red gates (Doc 02 / Doc 04).

○ Merge to main

`squash / merge`

Triggers Vercel production build automatically.

○ Production deploy

Vercel · `syd1`

Live within minutes; prior deploys retained for rollback.

○ Verify

`prod smoke + runtime logs`

Confirm against production; check Sentry / Vercel runtime logs.